MiSecure GmbH

Information Security Strategy

A Step-by-Step Framework for Building a Resilient Security Posture

Document Title:	Information Security Strategy – Step by Step
Author / CISO:	Chief Information Security Officer, MiSecure GmbH
Classification:	CONFIDENTIAL
Version:	1.0
Status:	Approved
Date:	2025-01-01
Review Cycle:	Annual
GitHub / LinkedIn:	Published as GRC Real-World Project

Reference: How to Draft Information Security Strategy for an Organization: Step by Step

Document Management

Version History

Version	Date	Description	Author	Approved By
1.0	2025-01-01	Initial release – baseline strategy	CISO	Board of Directors
0.9	2024-12-01	Draft for internal review	CISO	Strategy Committee
0.5	2024-10-01	First working draft	CISO	N/A

Document Distribution

Role	Name / Department	Access Level
Chief Executive Officer	CEO Office	Full
Chief Information Officer	IT Department	Full
Chief Information Security Officer	Security Team	Full
Risk & Compliance Manager	GRC Team	Full
Business Unit Owners	All Departments	Summary Only
External Auditors	Third Party	Read Only

Executive Summary

MiSecure GmbH operates in an increasingly complex and hostile digital threat landscape. This Information Security Strategy document establishes a structured, business-aligned roadmap for protecting the organization's information assets over a 3-to-5-year horizon (2025–2030).

The purpose of this strategy is threefold:

- To define MiSecure's security vision, objectives, and measurable goals
- To align security investments with business priorities and regulatory requirements
- To establish a governance framework that ensures accountability at every level

Why Information Security Matters for MiSecure

Information is MiSecure's most critical asset. A breach, ransomware attack, or insider threat does not merely create an IT problem — it creates a business continuity crisis, reputational damage, potential regulatory fines, and loss of customer trust. The following statistics frame the urgency:

- Average cost of a data breach globally: USD 4.45 million (IBM, 2024)
- Ransomware attacks increased by 73% year-over-year in 2024
- Human error accounts for 74% of all security incidents (Verizon DBIR, 2024)
- GDPR fines in the EU exceeded €2.1 billion in 2023

Strategic Intent

This strategy frames security not as a restrictive barrier, but as a business enabler — protecting company confidential and critical information while empowering employees to work securely and efficiently. We will achieve this through a structured approach mapped to the NIST Cybersecurity Framework (CSF):

NIST CSF Function	Core Objective	MiSecure Strategic Goal
IDENTIFY	Know what we have and what risks we face	Asset inventory, risk register, third-party management
PROTECT	Implement safeguards	IAM, encryption, awareness training, endpoint security
DETECT	Identify events quickly	SIEM, monitoring, vulnerability management
RESPOND	Act swiftly on incidents	Incident response plan, playbooks, forensics
RECOVER	Restore operations	Business continuity, disaster recovery, lessons learned

Background & Context

About MiSecure GmbH

MiSecure GmbH is a technology and services company providing secure solutions to enterprise customers across the DACH region (Germany, Austria, Switzerland). The organization operates a hybrid IT infrastructure combining on-premises data centers with cloud-based services (Microsoft Azure, Microsoft 365, SAP environments).

Current Technology Landscape

The following systems and technologies form the core of MiSecure's IT infrastructure, each requiring appropriate security controls:

- ERP / Business Systems: SAP (Fibu, cost center management), 3CX VoIP
- Virtualization: Citrix / Thinclient + Hyper-V, Proxmox
- Network: SonicWall NSA2700 Firewall, SMA500v VPN Gateway, UniFi Switching, Zabbix NMS
- Identity & Access: Active Directory, Tenfold IAM, Exchange / Outlook (ICEwarp)
- Storage: NetApp AFF220 (SAN/NAS), Proxmox with VHDX volumes
- Security Tools: SonicWall EDR/Endpoint Security, Zabbix monitoring, Ansible automation
- Web/App Servers: Apache + Nginx, Plesk, IIS, Let's Encrypt TLS
- Ticketing & Projects: Redmine, wiki for documentation
- Physical Security: CCTV/IPCAM (FSMRO), SMA Energy Management for building systems

Business Drivers for This Strategy

- Increasing regulatory requirements (GDPR, NIS2 Directive)
- Adoption of cloud and SaaS platforms increasing attack surface
- New remote work requirements and VPN expansion
- Digital transformation projects (HCI infrastructure, new data center strategy)
- Third-party risk exposure (Dresden-IT partnership, external suppliers)
- Growing threat of ransomware targeting SME organizations in Germany

Scope

In Scope

This Information Security Strategy applies to:

- All information assets owned, processed, or managed by MiSecure GmbH
- All employees, contractors, and third-party vendors with access to MiSecure systems
- All locations: Main office (Zentrale W3), branch locations (HV Sachsendorf/Madlow, HV Ost, HV Mitte West)
- All IT systems: On-premises servers, cloud infrastructure, network devices, endpoints
- All data classifications: Public, Internal, Confidential, and Restricted

Out of Scope

- Consumer-facing products not managed by internal IT
- Third-party managed systems where MiSecure has no administrative access
- Personal devices not enrolled in MDM (unless accessing MiSecure resources)

Data Classification Framework

Classification	Definition	Examples
Public	Approved for external distribution	Marketing materials, public website
Internal	For internal use only	Policies, procedures, internal memos
Confidential	Sensitive business information	Financial data, HR records, contracts
Restricted	Highly sensitive, limited access	Passwords, encryption keys, PII, medical data

Threat Landscape

External Threats

Threat	Category	Likelihood	Potential Impact
Ransomware attacks	Malware	HIGH	CRITICAL – business disruption
Phishing / Spear phishing	Social Engineering	HIGH	HIGH – credential theft
Supply chain attacks	Third-party risk	MEDIUM	HIGH – indirect compromise
Vulnerability exploitation	Technical attack	HIGH	HIGH – unauthorized access
DDoS attacks	Availability attack	MEDIUM	MEDIUM – service disruption
Nation-state espionage	APT	LOW	CRITICAL – IP theft

Internal Threats

Threat	Category	Likelihood	Potential Impact
Accidental data loss	Human error	HIGH	HIGH – data breach
Privilege misuse	Insider threat	MEDIUM	HIGH – unauthorized access
Shadow IT usage	Policy violation	MEDIUM	MEDIUM – unmanaged risk
Weak password practices	Access control	HIGH	HIGH – account compromise
Misconfigured systems	Technical error	MEDIUM	HIGH – exposure of data

Regulatory & Compliance Threats

- GDPR (EU 2016/679): Data protection and privacy obligations
- NIS2 Directive (EU 2022/2555): Network and information security requirements
- ISO/IEC 27001: International standard for information security management
- BSI IT-Grundschutz: German Federal Office for Information Security baseline
- SOC 2 (if applicable): Service organization controls for cloud services

Strategy Summary — 3 to 5 Year Roadmap (2025–2030)

The following phased roadmap defines MiSecure's strategic security evolution over five years, organized by NIST CSF functions:

Phase 1: Foundation (2025 — Year 1)

Goal: Build the baseline — know what we have, establish governance, close critical gaps.

- Complete asset inventory using LAN Sweeper + Netbox
- Deploy Zabbix for full network health monitoring and inventory
- Establish the Information Security Steering Committee
- Publish Information Security Policy and Data Classification Policy
- Deploy Tenfold IAM for Active Directory access management
- Begin SonicWall EDR rollout for all endpoints
- Conduct first security awareness training for all staff

Phase 2: Strengthen (2026–2027 — Years 2–3)

Goal: Harden controls, operationalize processes, reduce attack surface.

- Implement MFA across all critical systems (Citrix, VPN, Exchange, SAP)
- Complete SonicWall firewall rule review and tighten policies
- Deploy SIEM solution for centralized logging and alerting
- Establish Incident Response capability with documented playbooks
- Launch Vulnerability Management program (quarterly scans)
- Complete third-party risk assessments for key vendors
- Implement Let's Encrypt automated certificate management

Phase 3: Mature (2028–2030 — Years 4–5)

Goal: Achieve measurable maturity, align to ISO 27001, pursue certification.

- Pursue ISO/IEC 27001 certification
- Establish Security Operations Center (SOC) capability (internal or MSSP)
- Implement Zero Trust architecture principles
- Deploy advanced threat intelligence and threat hunting
- Achieve full integration of security into DevOps pipelines
- Conduct annual penetration testing and red team exercises

Governance & Organizational Structure

Strategy Steering Committee

The Information Security Steering Committee provides executive oversight and resource approval for all security initiatives. Members include:

Role	Person / Title	Responsibilities
CISO (Chair)	Chief Information Security Officer	Strategy ownership, program oversight
CIO	Chief Information Officer	IT alignment, resource decisions
CEO	Chief Executive Officer	Final budget approval, strategic direction
Risk Manager	GRC Team Lead	Risk register, compliance oversight
Business Unit Owners	Dept. Managers	Business process requirements, certifications
Legal Counsel	Legal Dept.	Regulatory requirements, contracts

RACI Matrix — Key Security Responsibilities

Activity	CISO	CIO	CEO	BU Owners	IT Team
Strategy Development	R/A	C	I	C	I
Policy Approval	R	C	A	I	I
Risk Assessment	R/A	C	I	C	R
Access Certification	A	I	I	R	I
Incident Response	A	R	I	C	R
Security Training	R/A	I	I	C	R
Vulnerability Mgmt	A	C	I	I	R

R=Responsible | A=Accountable | C=Consulted | I=Informed

Security Initiatives

Each initiative follows the three-element framework: Intent → Goal → Success Criteria.

Initiative 1: Identity & Access Management (IAM)

Element	Description
Intent	To ensure only authorized individuals access MiSecure systems and data, with appropriate privilege levels, reducing the risk of unauthorized access and insider threats.
Goal	Deploy Tenfold IAM to automate Active Directory provisioning/de-provisioning; enforce Least Privilege; implement MFA on all critical systems.
Owner	CISO / IT Team
Timeline	Phase 1–2 (2025–2026)
Success Criteria	100% of users provisioned via Tenfold; quarterly access certifications by BU owners; MFA adoption rate ≥95%; zero orphaned accounts after 30 days.
Tools	Tenfold, Active Directory, Azure AD, MFA (Microsoft Authenticator)

Initiative 2: Network Security & Perimeter Defense

Element	Description
Intent	To protect MiSecure's network infrastructure from unauthorized access, malicious traffic, and lateral movement by attackers.
Goal	Maintain and optimize SonicWall NSA2700 firewall rules; upgrade VPN to SMA500v; segment network with Nexus switches; deploy Zabbix for full visibility.
Owner	IT Team / CISO
Timeline	Phase 1–2 (2025–2027)
Success Criteria	Firewall rule review completed annually; zero unmanaged network segments; VLAN segmentation for all critical systems; Zabbix coverage ≥98% of devices.
Tools	SonicWall NSA2700, SMA500v VPN, UniFi, Nexus switches, Zabbix

Initiative 3: Endpoint Security & EDR

Element	Description
Intent	To protect all endpoints (workstations, servers, mobile devices) from malware, ransomware, and unauthorized access.
Goal	Deploy SonicWall EDR + Capture Client to all endpoints; enforce device compliance; manage patches centrally.

Element	Description
Owner	IT Team
Timeline	Phase 1–2 (2025–2026)
Success Criteria	100% endpoint EDR coverage; critical patches applied within 72h; monthly vulnerability scan reports; zero unmanaged endpoints.
Tools	SonicWall Capture Client EDR, Windows Defender, WSUS, Ansible

Initiative 4: Risk Management

Element	Description
Intent	To identify, assess, and treat information security risks before they materialize into incidents.
Goal	Establish a formal Risk Management Program using ISO 27005 methodology; maintain a live risk register; conduct quarterly risk reviews.
Owner	CISO / Risk Manager
Timeline	Phase 1–3 (2025–2030)
Success Criteria	Risk register published and updated quarterly; all HIGH risks have treatment plans; annual risk report presented to Steering Committee.
Tools	Redmine (risk tracking), Excel risk register, ISO 27005 framework

Initiative 5: Security Awareness & Training

Element	Description
Intent	To build a security-conscious culture where every employee understands their role in protecting MiSecure's information assets.
Goal	Deliver mandatory annual security awareness training; conduct quarterly phishing simulations; role-based training for privileged users.
Owner	CISO / HR
Timeline	Phase 1 onward (from 2025)
Success Criteria	100% staff completion of annual training; phishing click rate <5%; security culture score improvement year-over-year.
Tools	KnowBe4 or equivalent LMS, phishing simulation platform, internal wiki

Initiative 6: Incident Response & Business Continuity

Element	Description
Intent	To ensure MiSecure can rapidly detect, contain, and recover from security incidents with minimal business impact.
Goal	Develop and test Incident Response Plan (IRP); establish communication

Element	Description
	protocols; maintain tested backups; define RTO/RPO for critical systems.
Owner	CISO / IT Team / Management
Timeline	Phase 2 (2026–2027)
Success Criteria	IRP tested at least twice per year (tabletop + simulation); RTO ≤4h for critical systems; backup restoration tested quarterly; post-incident reviews for all P1 incidents.
Tools	Documented IRP, APC UPS, backup solutions (Proxmox, NetApp snapshots), 3CX communications

Initiative 7: Vulnerability Management

Element	Description
Intent	To continuously identify and remediate security vulnerabilities before attackers can exploit them.
Goal	Conduct regular vulnerability scans; prioritize by CVSS severity; track remediation in Redmine; perform annual penetration tests.
Owner	IT Team / CISO
Timeline	Phase 2–3 (2026–2030)
Success Criteria	Monthly automated scans; critical CVEs remediated within 24h; high CVEs within 7 days; annual pen test report.
Tools	OpenVAS/Tenable, Zabbix, LAN Sweeper, Redmine

Initiative 8: Data Protection & Compliance

Element	Description
Intent	To ensure MiSecure meets all legal, regulatory, and contractual obligations related to data protection and privacy.
Goal	Maintain full GDPR compliance; implement Lancrypt data encryption; conduct annual compliance audits; manage third-party data processing agreements.
Owner	CISO / Legal / Compliance
Timeline	Ongoing (all phases)
Success Criteria	Zero GDPR violations; all DPAs in place for processors; annual DPIA completed; data breach response within 72h (as required by GDPR Art. 33).
Tools	Lancrypt encryption, Redmine compliance tracker, GDPR documentation templates

Key Performance Indicators (KPIs) & Metrics

Success metrics are reported quarterly to the Steering Committee. The following KPIs track progress against each initiative:

KPI / Metric	Target	Reporting Frequency	Owner
MFA adoption rate	≥95%	Monthly	CISO
Orphaned account removal time	<30 days	Monthly	IT Team
Security training completion	100%	Annually	CISO/HR
Phishing simulation click rate	<5%	Quarterly	CISO
Critical vulnerability remediation	<24 hours	Per incident	IT Team
High vulnerability remediation	<7 days	Per incident	IT Team
Patch compliance rate	≥95%	Monthly	IT Team
IRP tests per year	≥2	Annually	CISO
RTO for critical systems	≤4 hours	Per incident	IT/CISO
Risk register updates	Quarterly	Quarterly	Risk Mgr
Security incidents (P1)	Trend: decreasing	Monthly	CISO
GDPR data breach notification	<72 hours	Per incident	Legal/CISO
Zabbix device coverage	≥98%	Monthly	IT Team

Implementation Timeline

The following master schedule outlines all initiatives, phases, budget status, and ownership:

Initiative	Start	End	Budget Status	Owner
1. Identity & Access Management	Q1 2025	Q4 2026	Approved (CISO)	CISO / IT Team
2. Network Security & Perimeter	Q1 2025	Q4 2027	Approved (CIO)	IT Team
3. Endpoint Security & EDR	Q1 2025	Q4 2026	Approved (CISO)	IT Team
4. Risk Management Program	Q1 2025	Ongoing	Approved (CISO)	CISO / Risk Mgr
5. Security Awareness Training	Q2 2025	Ongoing	Approved (HR/CISO)	CISO / HR
6. Incident Response & BCP	Q1 2026	Q4 2027	Funding: CIO needed	CISO / IT / Mgmt
7. Vulnerability Management	Q1 2026	Ongoing	Approved (CIO)	IT Team / CISO
8. Data Protection & Compliance	Q1 2025	Ongoing	Approved (Legal)	CISO / Legal
9. SIEM Implementation	Q1 2026	Q4 2026	Funding: Board needed	CISO
10. ISO 27001 Certification	Q1 2028	Q4 2029	Funding: CEO needed	CISO / External Audit

Information Security Policy Framework

The strategy is backed by a hierarchy of policies. Each policy document references this strategy as its governing authority.

Policy Document	Scope / Purpose	Status
Information Security Policy (Master)	Overarching security law of MiSecure	To be published Q1 2025
Access Control Policy	IAM, least privilege, MFA requirements	Draft
Data Classification & Handling Policy	Data labels, handling rules per class	Draft
Acceptable Use Policy (AUP)	Employee device/internet usage	To be published Q1 2025
Incident Response Policy	IR roles, escalation, reporting	In development
Business Continuity Policy	BCP/DR plans, RTO/RPO	In development
Third-Party Risk Policy	Vendor security requirements	Planned 2025
Vulnerability Management Policy	Scan schedules, SLAs	Planned 2026
Remote Work & VPN Policy	Secure remote access requirements	Draft
Password & Authentication Policy	Complexity, rotation, MFA mandates	To be published Q1 2025

Communication Strategy

Positive Framing Principle

As CISO, all security communications should position security as a business enabler, not a barrier. We protect what matters most — our people, our customers, and our business.

Instead of saying...	Say this instead...
'We are prohibiting unauthorized access'	'We are protecting company confidential and critical information'
'You cannot use this system'	'This system requires approval to ensure data stays protected'
'Security blocks this action'	'Security ensures this action meets our protection standards'
'This is mandatory compliance'	'This helps us meet our obligations to our customers and partners'

Stakeholder Communication Plan

Audience	Communication Type	Frequency	Format
Board / CEO	Strategy status & risk summary	Quarterly	Executive dashboard
Steering Committee	Initiative updates & KPIs	Monthly	Steering report
Department Managers	Policy updates & training	As needed	Email + briefing
All Employees	Security awareness & reminders	Monthly	Newsletter + LMS
IT Team	Technical updates & tasks	Weekly	Stand-up + Redmine
External Auditors	Evidence & compliance docs	Annually	Audit pack

Conclusion

This Information Security Strategy represents MiSecure GmbH's commitment to building and maintaining a world-class information security posture. By following this structured, phased roadmap, we will:

- Reduce the risk of data breaches, ransomware, and unauthorized access
- Align security with business goals and regulatory requirements
- Build a culture where every employee is a security partner
- Achieve measurable, transparent security maturity over five years
- Protect our customers, our employees, and our reputation

This strategy is a living document. It will be reviewed annually by the Steering Committee and updated to reflect changes in the threat landscape, business environment, and regulatory requirements.

Security is not just a technology problem — it is a business imperative. By investing in the right people, processes, and technologies today, MiSecure will be positioned not just to survive in the digital age, but to thrive.

Signed: Chief Information Security Officer, MiSecure GmbH

Version 1.0 | January 2025 | CONFIDENTIAL